Endorsements for Attestation: A Common Language for the Whole Supply Chain

Paul Howard *Senior Principal Software Architect, Arm*

Shefali Kamal *Software Architect, Fujitsu*

OCP
PLATINUM®
Member

Agenda

Attestation and Supply Chains

The importance of the Confidential AI use case, and how this creates a challenge for the industry

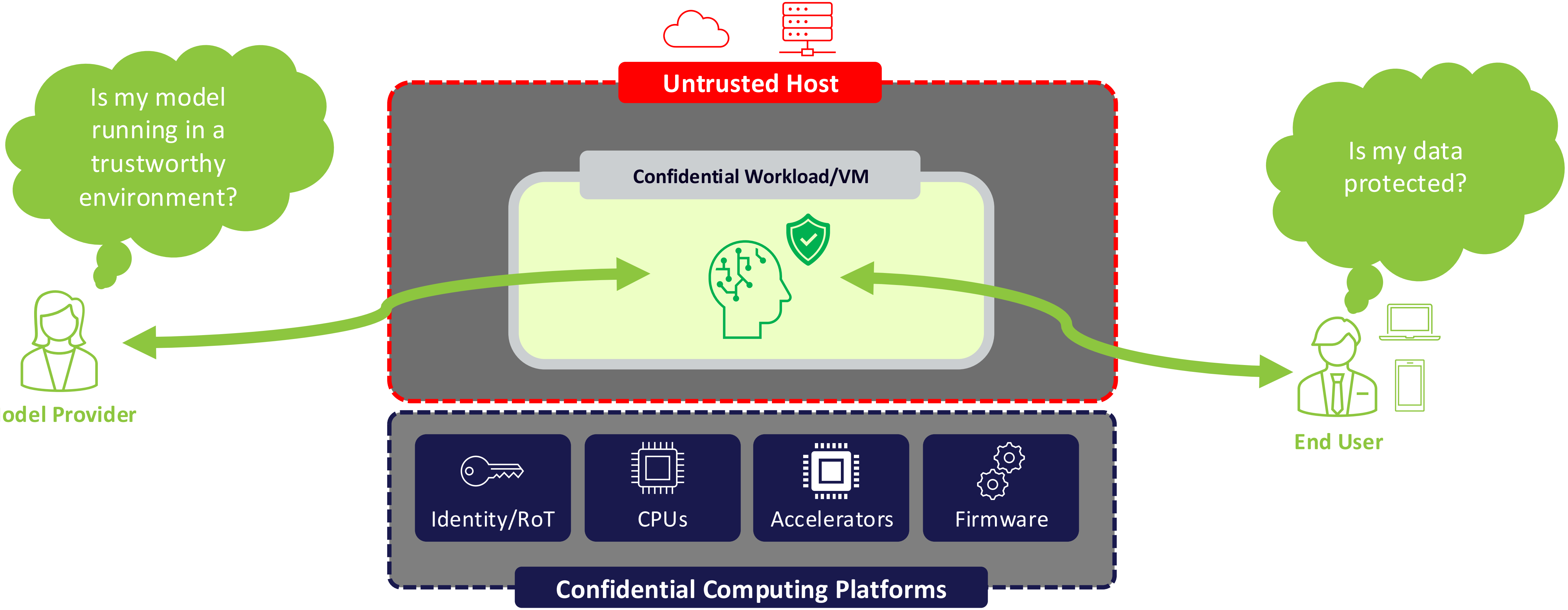
Towards a Common Language

Progress on standardization efforts for endorsement and reference value distribution

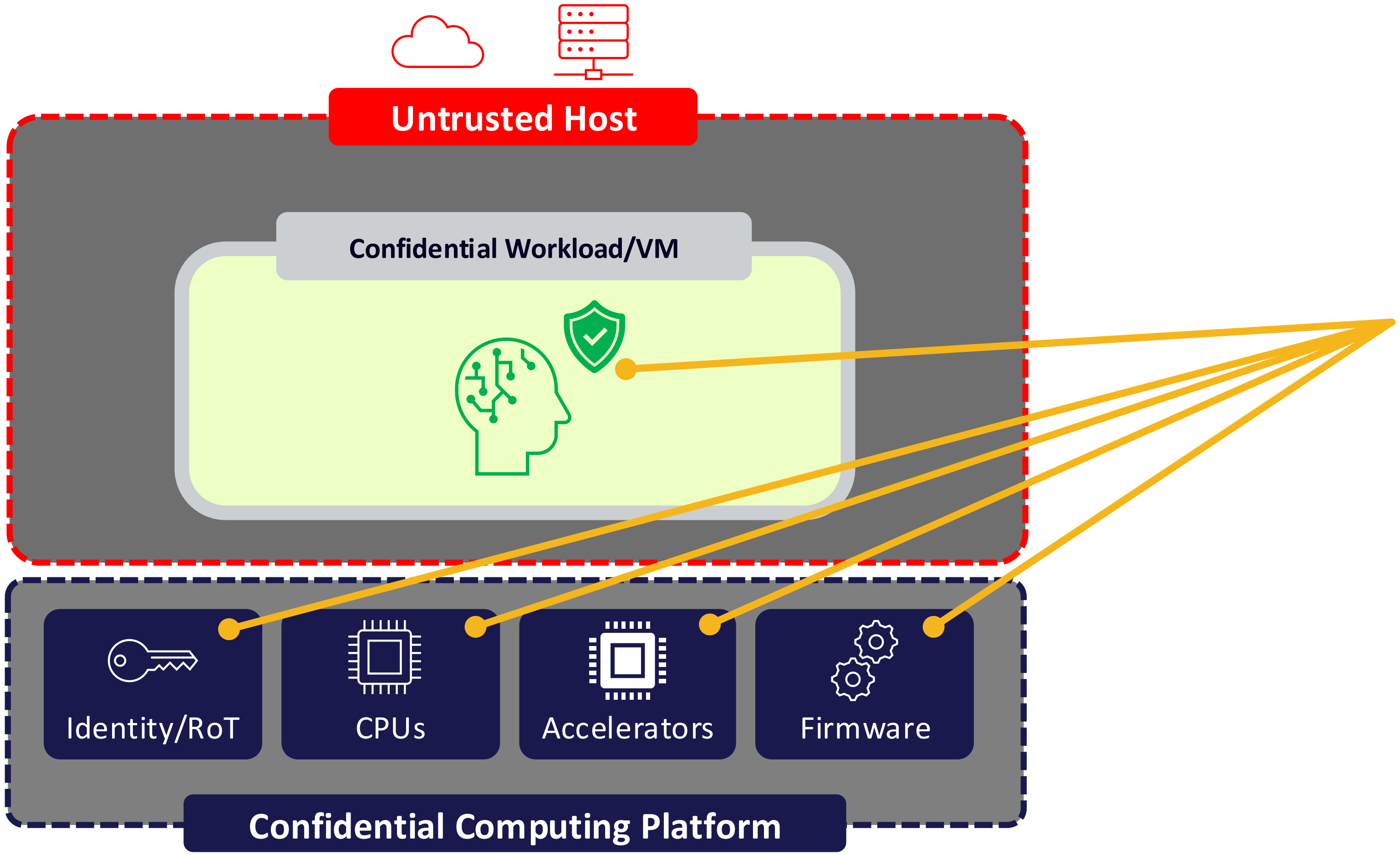
Progress in Open Source

How open source is being used to demonstrate and evolve the solution, and how **you** can be a part of it

Attestation and Confidential AI

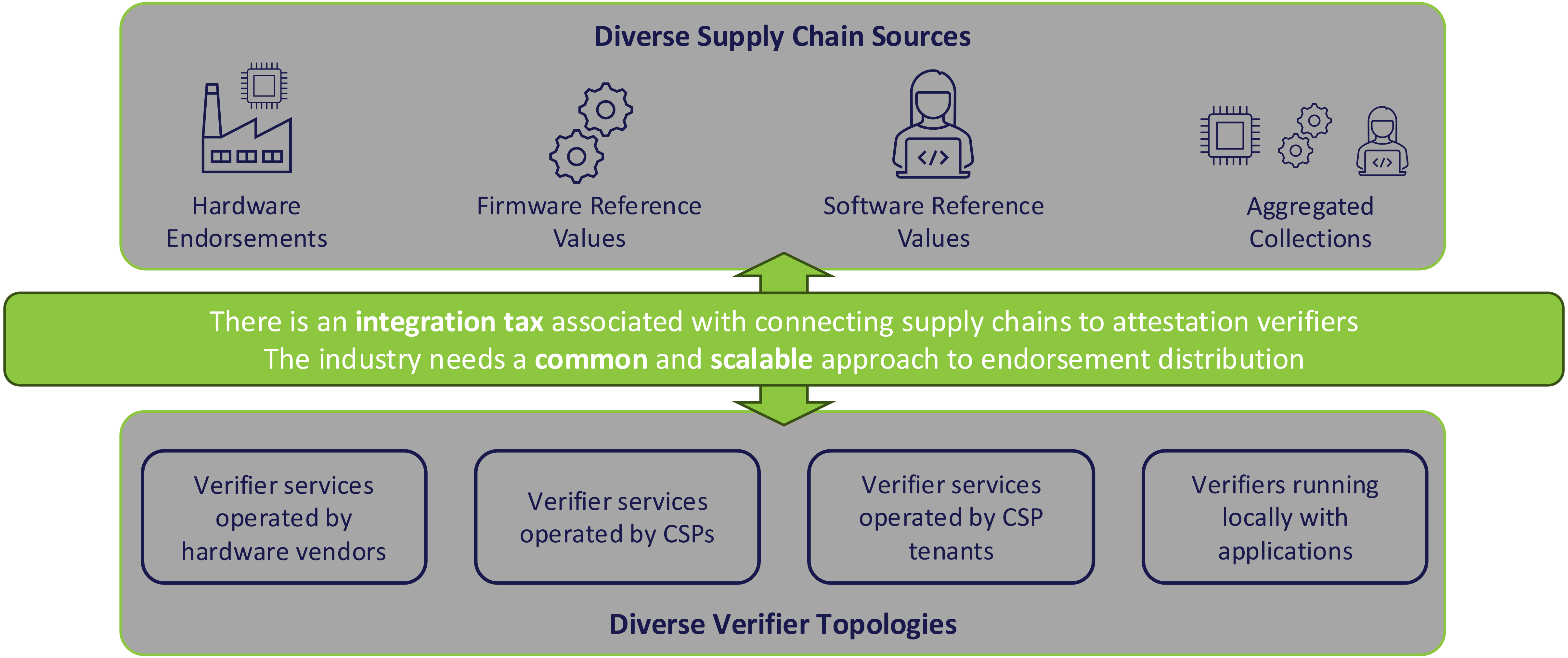

Is my model running in a trustworthy environment?
Model Provider
Untrusted Host
Confidential Workload/VM
Identity/RoT
CPUs
Accelerators
Firmware
Confidential Computing Platforms
Is my data protected?
End User

Attestation Complexity


Untrusted Host
Confidential Workload/VM
Identity/RoT
CPUs
Accelerators
Firmware
Confidential Computing Platform

There are multiple sources of **attestation evidence**, all of which needs to be **verified**, based on **sources of truth** from the **supply chain**

Connecting Supply Chains to Verifiers



Diverse Supply Chain Sources

Hardware Endorsements

Firmware Reference Values

Software Reference Values

Aggregated Collections

There is an **integration tax** associated with connecting supply chains to attestation verifiers
The industry needs a **common** and **scalable** approach to endorsement distribution

Verifier services operated by hardware vendors

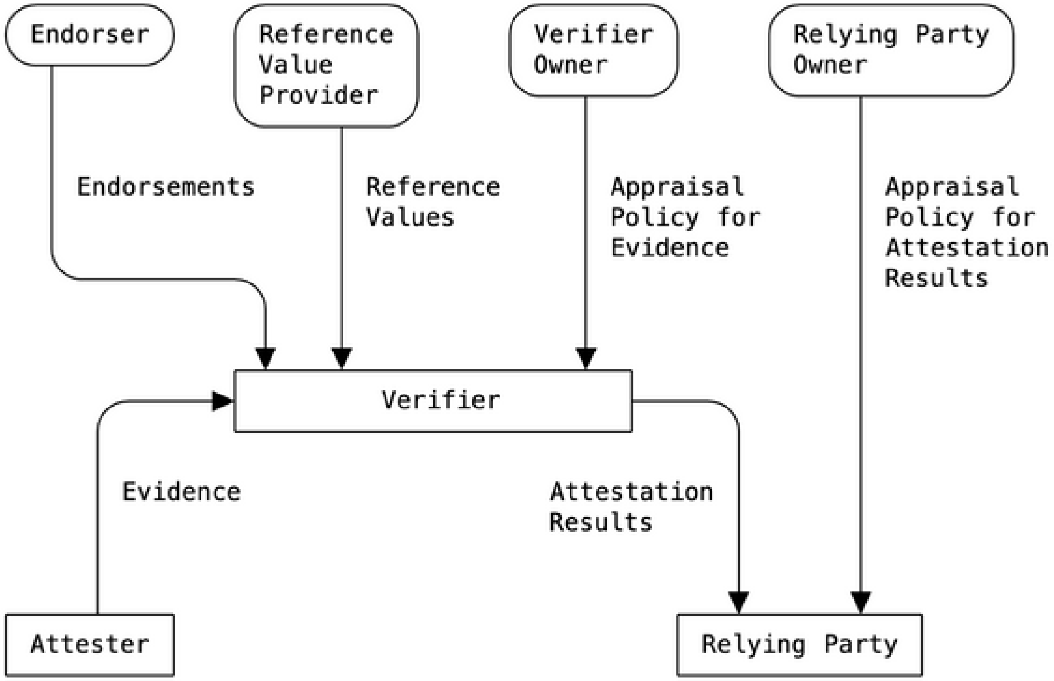
Verifier services operated by CSPs

Verifier services operated by CSP tenants

Verifiers running locally with applications

Diverse Verifier Topologies

IETF RATS: The Place to Standardize


Endorser
Reference Value Provider
Verifier Owner
Relying Party Owner
Endorsements
Reference Values
Appraisal Policy for Evidence
Appraisal Policy for Attestation Results
Verifier
Evidence
Attestation Results
Attester
Relying Party

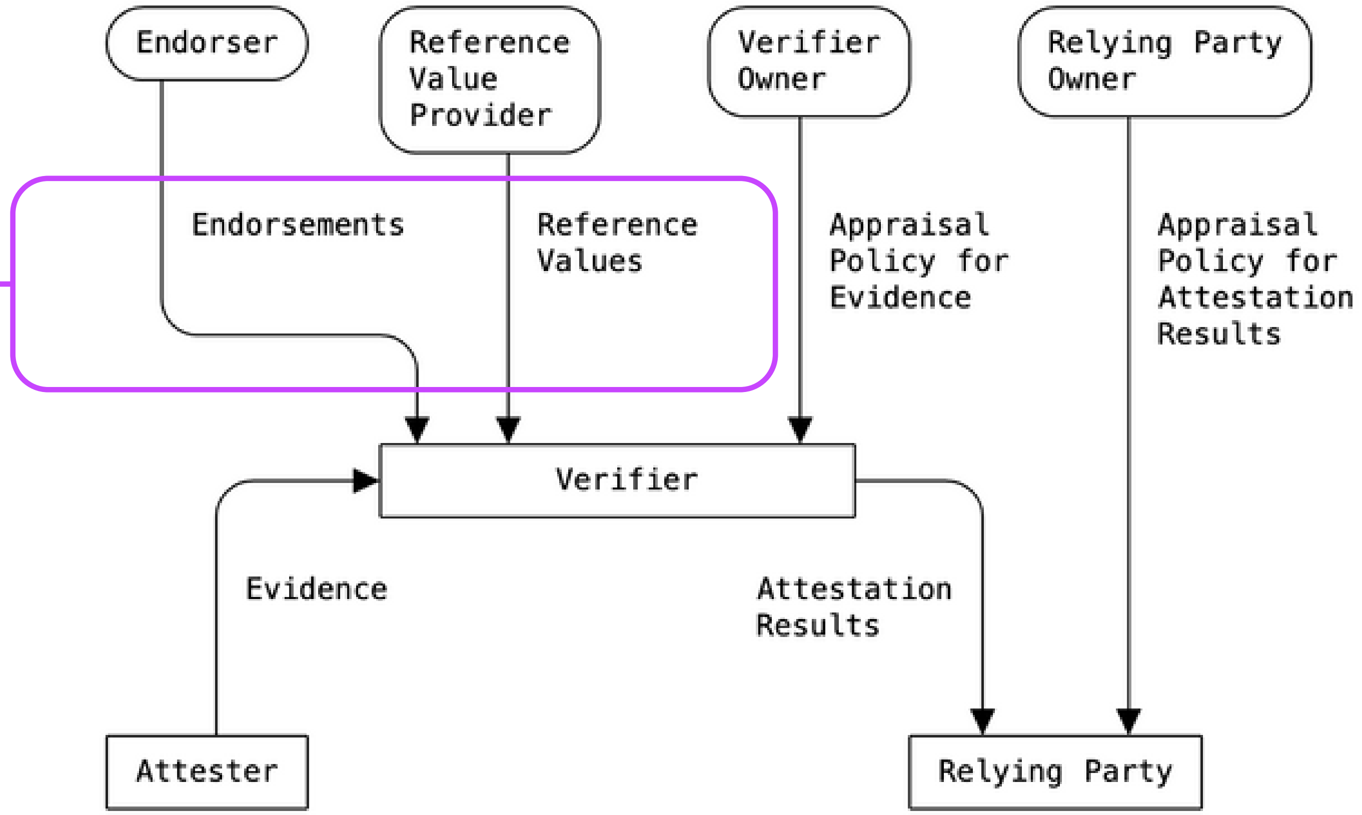
RATS Architecture (RFC9334)

- The RATS Working Group is an expert community that considers **all aspects of attestation** based on a **common architectural template**
- RATS looks for opportunities to standardize data formats, interaction models, and **conveyances**
- Standardization efforts are **connected**, making them useful in **combinations**
- It’s the **right place to solve the endorsement distribution problem**

CoSERV

CoSERV is a **conveyance protocol** that helps Verifiers consume Endorsements and Reference Values from multiple or complex supply-chain sources

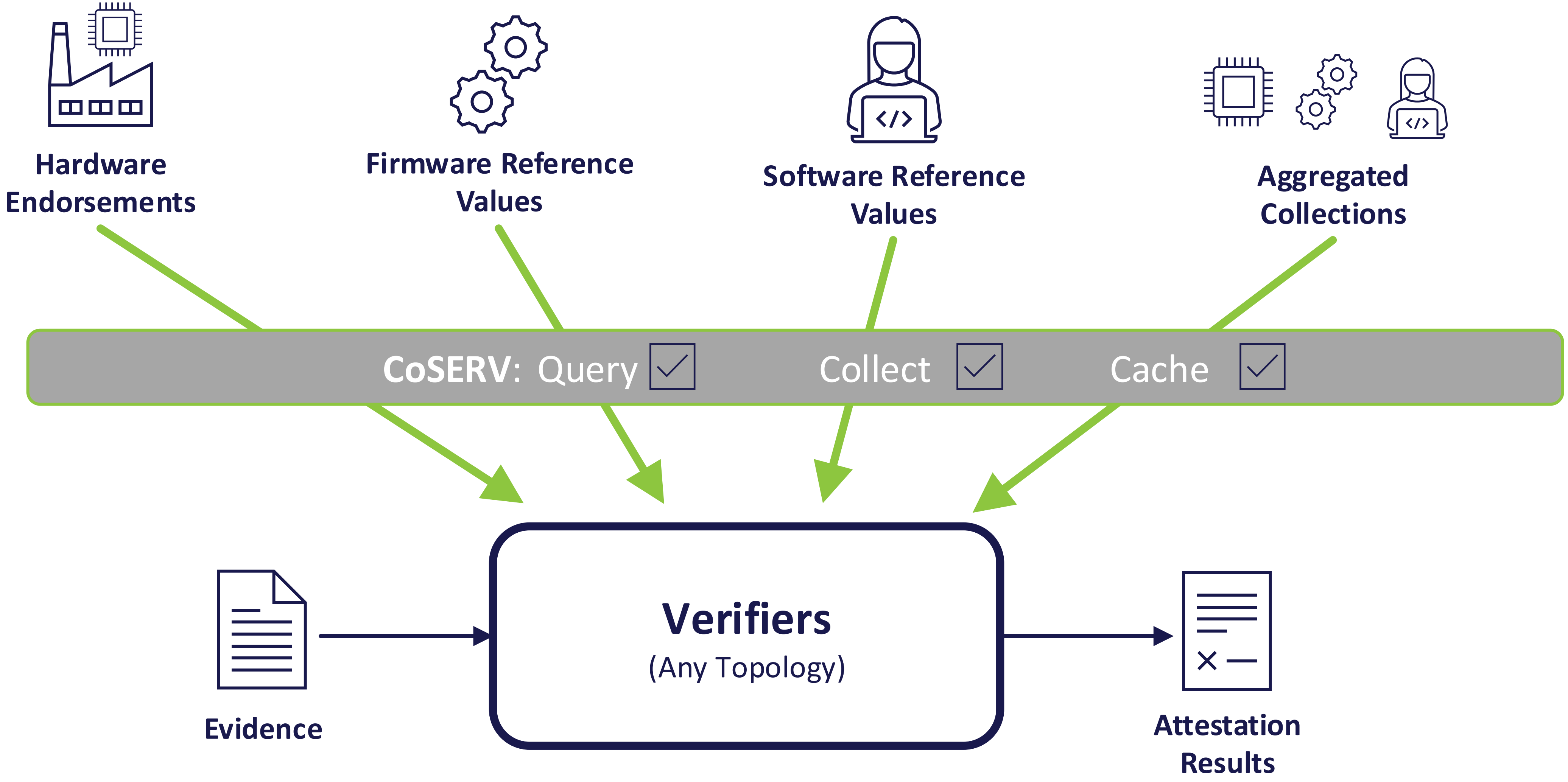
Data formats (such as **CoRIM**) are gaining traction here, but there are no APIs to facilitate efficient interactions


Endorser
Reference Value Provider
Verifier Owner
Relying Party Owner
Endorsements
Reference Values
Appraisal Policy for Evidence
Appraisal Policy for Attestation Results
Verifier
Evidence
Attestation Results
Attester
Relying Party

Concise **S**elector for **E**ndorsements and **R**eference **V**alues

https://datatracker.ietf.org/doc/draft-ietf-rats-coserv/

Harmonized, Flexible Artifact Distribution



Hardware Endorsements

Firmware Reference Values

Software Reference Values

Aggregated Collections

CoSERV: Query ☑ Collect ☑ Cache ☑

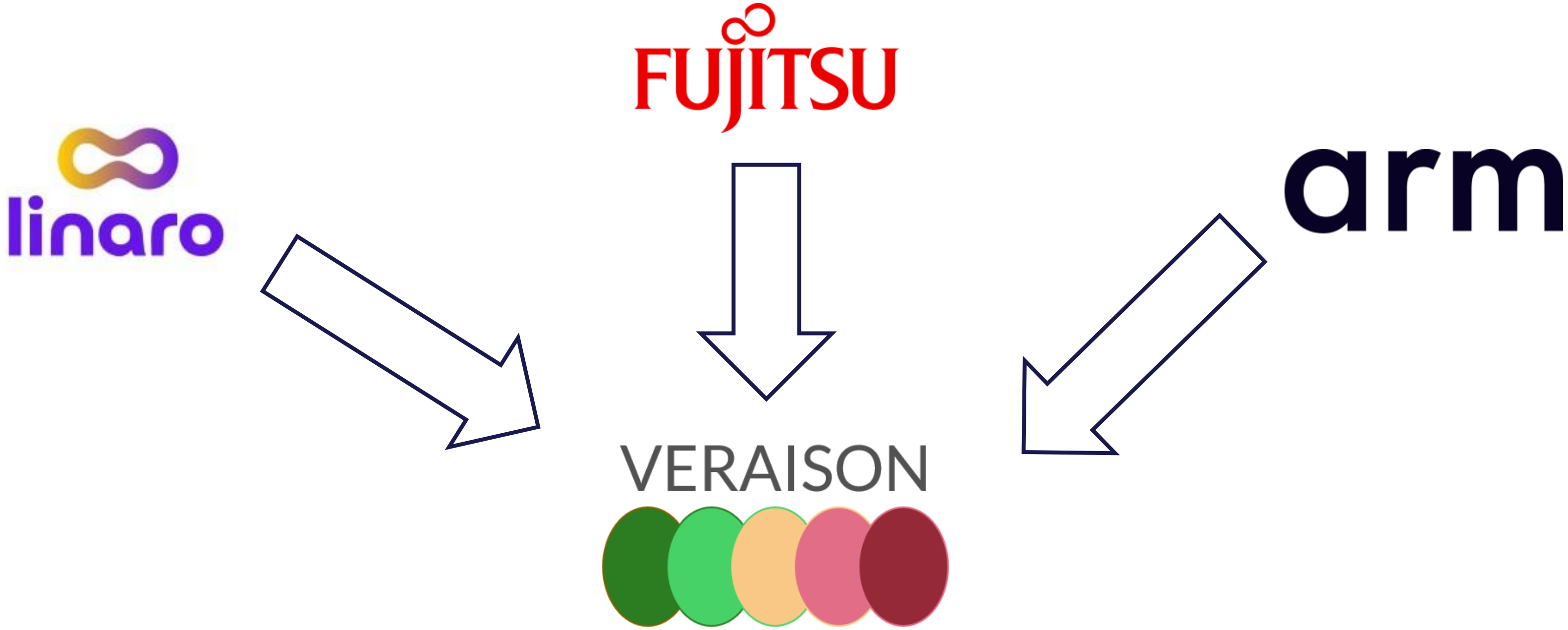
Evidence

Verifiers

(Any Topology)

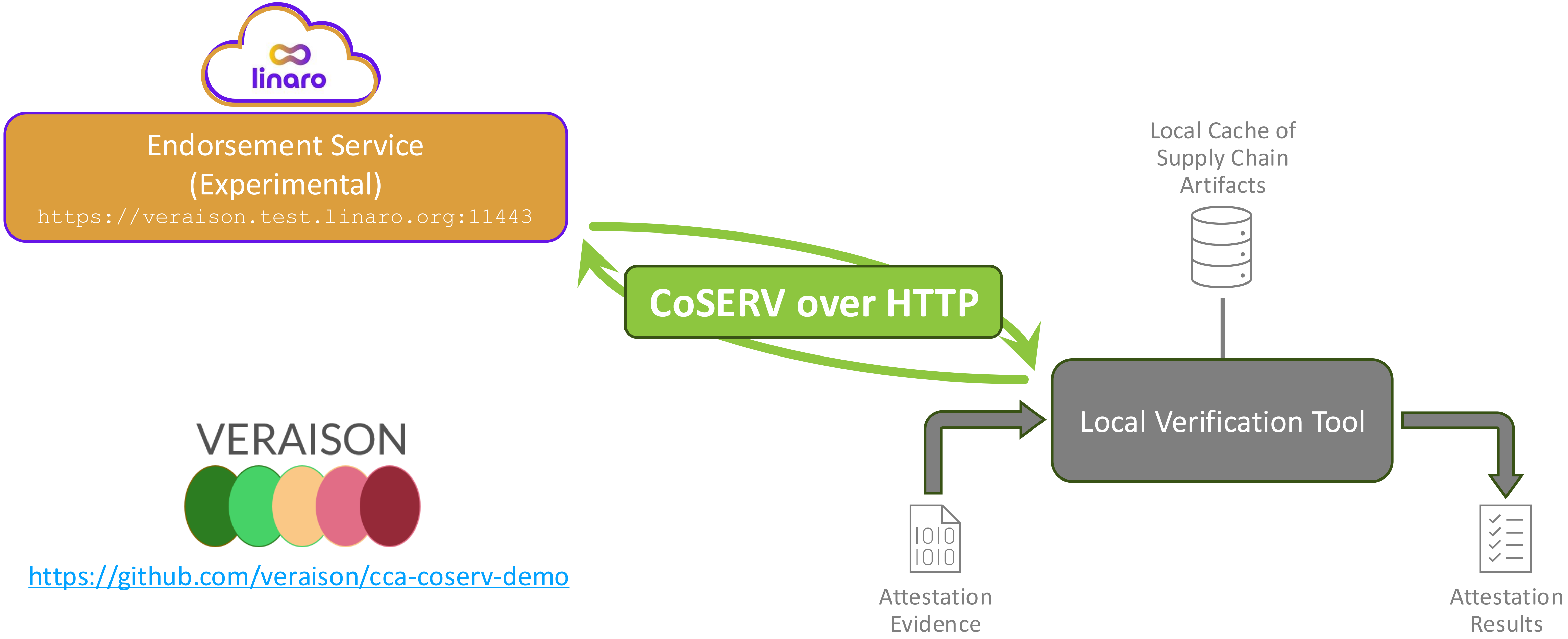
Attestation Results

CoSERV in Veraison


FUJITSU
linaro
arm
VERAISON

The **Veraison** project is the ideal place to show how the CoSERV standard can be implemented and used in practice

End-to-End Proof of Concept



Endorsement Service
(Experimental)
`https://veraison.test.linaro.org:11443`

CoSERV over HTTP

Local Cache of
Supply Chain
Artifacts

Local Verification Tool

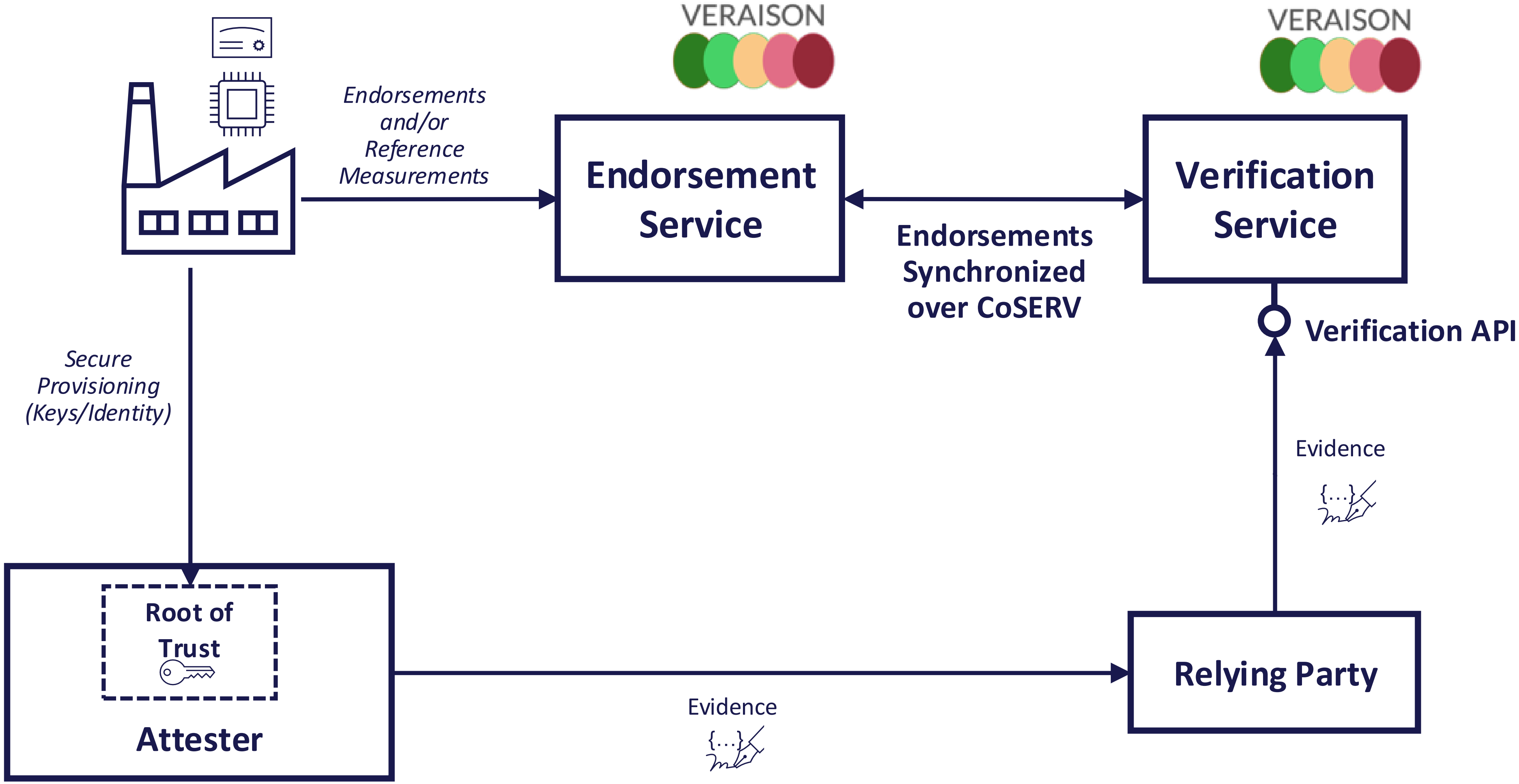
Attestation
Evidence

Attestation
Results

VERAISON

https://github.com/veraison/cca-coserv-demo

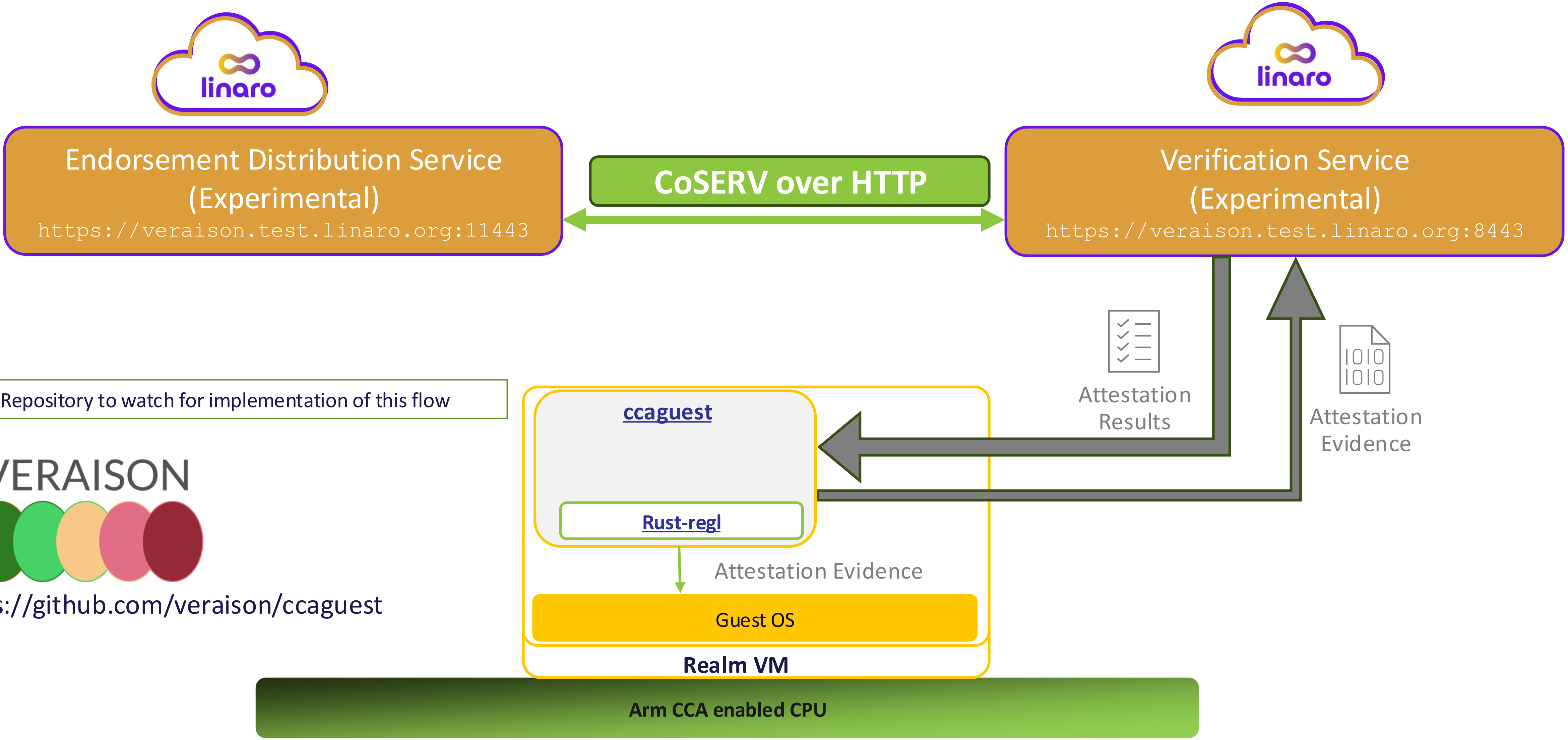
Future Work: Veraison in Multiple Roles



VERAISON
VERAISON
Endorsements and/or Reference Measurements
Endorsement Service
Verification Service
Endorsements Synchronized over CoSERV
Verification API
Secure Provisioning (Keys/Identity)
Evidence
{…}
Root of Trust
Attester
Evidence
{…}
Relying Party

https://github.com/veraison/services/issues/387

Future Work: Implementation Details In Veraison



Endorsement Distribution Service (Experimental)
`https://veraison.test.linaro.org:11443`

CoSERV over HTTP

Verification Service (Experimental)
`https://veraison.test.linaro.org:8443`

Attestation Results

Attestation Evidence

ccaguest

Rust-regl

Attestation Evidence

Guest OS

Realm VM

Arm CCA enabled CPU

Repository to watch for implementation of this flow

VERAISON

https://github.com/veraison/ccaguest

Call to Action

- We need to **make attestation deployable at scale** for Confidential Computing use cases
- Let's align around **a common language and interface** for endorsement distribution to verifiers
- Consider offering **CoSERV-compatible endpoints** (alongside existing APIs)
- Use the pre-RFC status as an **opportunity to evolve the standard** for your use cases
- **Participate** via IETF or the Veraison project
    - CoSERV IETF Draft: https://datatracker.ietf.org/doc/draft-ietf-rats-coserv/
    - CoSERV GitHub Repo: https://github.com/ietf-rats-wg/draft-ietf-rats-coserv
    - Veraison: https://github.com/veraison
    - Veraison CoSERV end-to-end demo: https://github.com/veraison/cca-coserv-demo
    - Veraison ccaguest repo: https://github.com/veraison/ccaguest

Thank You!